TITLE:
Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity based user-to-application connectivity without exposing internal networks.

Group Details:

S.no	Name	College Name	Contact
1	NOUFAL I	Sree Narayana Guru College	noufal8116@gmail.com
2	HRITHIKA V	Sree Narayana Guru College	hrithikaammu26@gmail.com
3	AMAL SHAS K A	Sree Narayana Guru College	amalshas2580@gmail.com
4	VIGNESH M	Sree Narayana Guru College	vigneshvishnukumarctr@gmail.com

PROJECT DETAILS

Title: Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks.

Introduction:

Zero Trust Network Access (ZTNA) is a modern cybersecurity approach designed to protect organizational resources and applications. Unlike traditional security models that trust users inside the network, ZTNA follows the principle of "Never Trust, Always Verify." In this model, every user and device must be authenticated before accessing any application. This helps organizations prevent unauthorized access and reduce security risks. Zscaler provides a cloud-based platform that implements ZTNA to secure user-to-application connectivity. It allows users to securely access internal applications without exposing the entire network to the internet. With the increase in remote work and cloud services, secure access has become very important. ZTNA ensures that users can only access the applications they are authorized to use. It also continuously monitors user activity to detect threats. By using ZTNA solutions like those provided by Zscaler, organizations can improve security while enabling flexible and safe access to applications.

ABSTRACT:

Zero Trust Network Access (ZTNA) is an advanced security model designed to protect organizational applications and data from unauthorized access. It follows the principle of "Never Trust, Always Verify," where every user and device must be authenticated before accessing any resource. Traditional network security models rely on perimeter-based protection, which is not effective for modern cloud and remote work environments. Zscaler provides a cloud-based ZTNA solution that securely connects users to applications without exposing the internal network. The system verifies user identity, device status, and security policies before granting access. This approach reduces the risk of cyberattacks and data breaches. It also provides secure access for remote users and improves overall network security. ZTNA limits user access only to authorized applications, preventing unnecessary network exposure. Continuous monitoring helps detect and prevent suspicious activities. Therefore, implementing ZTNA with Zscaler enhances secure and reliable user-to-application connectivity.

USE CASE SCENARIOS

1. Secure Remote Employee Access

Employees working remotely often need access to company applications and internal resources. With **Zscaler Private Access**, users can securely connect to applications from any location without using traditional VPNs. The system verifies the identity of the user and checks the device security before granting access. This ensures safe remote connectivity while protecting the organization's network from unauthorized users.

2. Third-Party Vendor Access

Organizations sometimes allow external vendors or partners to access specific internal applications for business purposes. ZTNA allows administrators to provide restricted access only to the required applications instead of giving full network access. This minimizes the risk of data leaks or unauthorized activities within the network. By using ZTNA solutions from **Zscaler**, organizations can securely manage vendor access.

3. Secure Cloud Application Access

Many companies use cloud-based applications for storing data and running business operations. ZTNA ensures that only authenticated and authorized users can access these applications. The platform checks user identity, device health, and security policies before allowing the connection. This improves security and prevents unauthorized access to sensitive cloud data.

4. Branch Office Connectivity

Large organizations often have multiple branch offices that need secure access to internal applications. ZTNA provides a secure connection between branch

offices and company applications without exposing the entire network. The system ensures that only authorized users and devices can access the applications. This improves security while maintaining smooth communication between different office locations.

5. Bring Your Own Device (BYOD) Security

Employees often use personal devices like laptops, tablets, or smartphones to access company resources. ZTNA allows organizations to securely support the BYOD model while maintaining strong security controls. The system verifies the device security status before granting access to any application. This helps organizations protect sensitive data even when employees use personal devices.

STAGE 1

Title of the project: -

Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user-to-application connectivity without exposing internal networks.

Overview:

Zero Trust Network Access (ZTNA) is a modern cybersecurity framework designed to protect organizational applications and data from unauthorized access. Traditional security systems rely on perimeter-based protection, where users inside the network are automatically trusted. However, this model is no longer effective due to the increasing use of cloud services, remote work, and mobile devices. ZTNA addresses these challenges by following the principle of "Never Trust, Always Verify." In this approach, every user and device must be verified before accessing any application or resource.

The ZTNA model focuses on identity-based security instead of network location. It ensures that users are granted access only to the specific applications they are authorized to use. This reduces the risk of internal threats and limits the movement of attackers within the network. Zscaler provides a cloud-based platform that implements ZTNA to secure user-to-application connectivity. Its solution allows organizations to connect users directly to applications without exposing the internal network to the internet.

One of the key solutions offered by Zscaler is Zscaler Private Access, which replaces traditional VPN-based access. It creates a secure and direct connection between the user and the application. The platform continuously verifies the identity of the user and the security status of the device. Security policies are applied before granting access to ensure that only authorized users can connect.

ZTNA also improves visibility and control over network activities. Organizations can monitor user behaviour and detect suspicious activities in real time. This helps in preventing cyberattacks, data breaches, and unauthorized access attempts. As organizations increasingly adopt digital transformation and remote work models, ZTNA has become an important security solution for protecting modern enterprise environments.

List of Vulnerability Table:

S.no	Vulnerability Name	CWE/CVE - No
1	Absolute Path Traversal	CWE-36
2	External Control of System or Configuration Setting	CWE-15
3	Use of Unmaintained Third Party Components	CWE-1104
4	Missing Cryptographic Step	CWE-325
5	Improper Neutralization of Equivalent Special Elements	CWE-76
6	External Control of File Name or Path	CWE-73
7	Improper Authentication	CWE-287
8	Untrusted Search Path	CWE-426
9	Insertion of Sensitive Information into Log File	CWE-532
10	Detection of Error Condition Without Action	CWE-390

REPORT:-

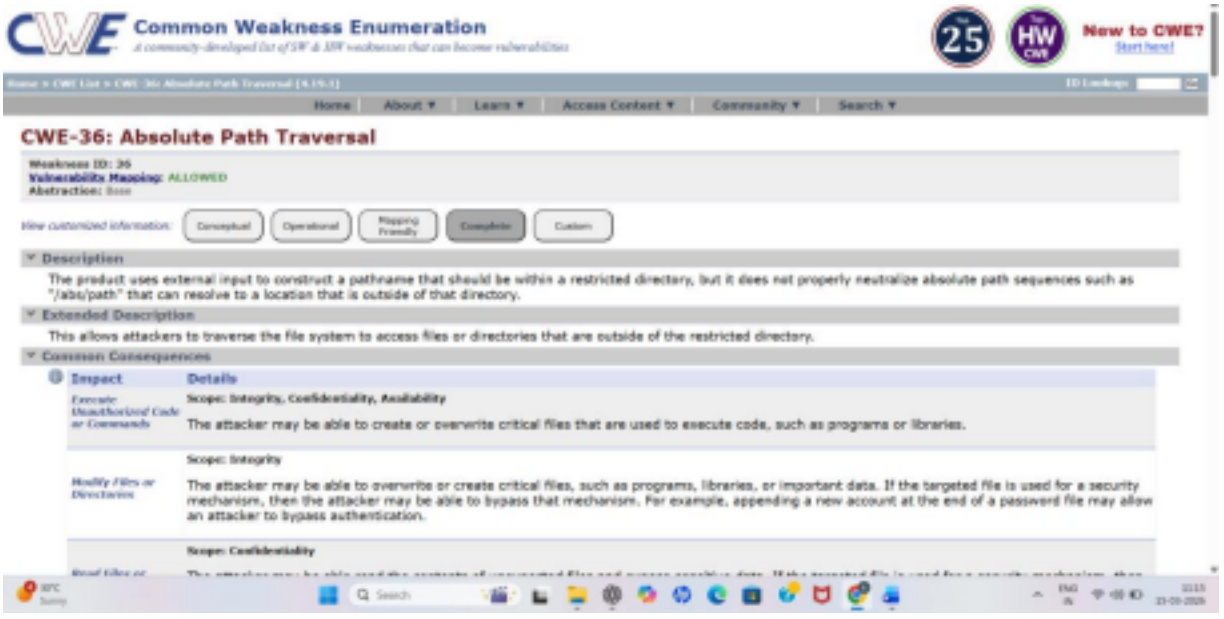
1)Vulnerability Name:- Absolute Path Traversal

CWE/CVE : - CWE-36

OWASP/SANS Category:- A01:2025 Broken Access Control

Description:- Absolute Path Traversal occurs when a web application allows users to access files and directories using absolute file paths without proper validation. Attackers can manipulate input parameters to access files located outside the intended directory. This vulnerability allows unauthorized users to bypass access restrictions and retrieve sensitive files stored on the server.

Business Impact:- If exploited, attackers may gain access to confidential system files, application configuration files, or sensitive user data. This may lead to unauthorized data disclosure, system compromise, or further exploitation of other vulnerabilities within the system.



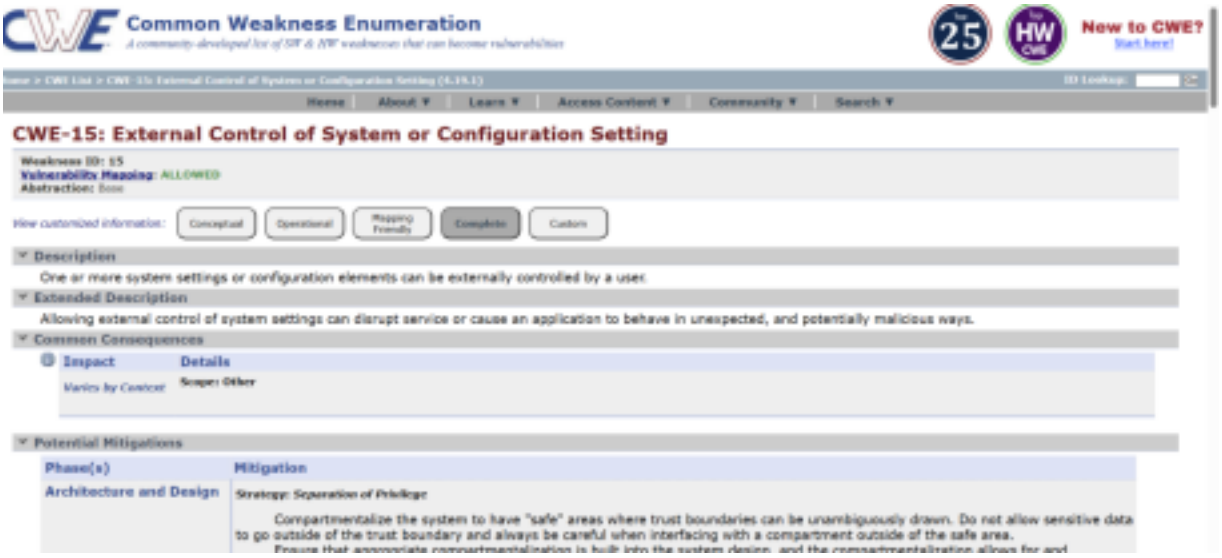
2)Vulnerability Name :- External Control of System or Configuration Setting

CWE/CVE:- CWE-15

OWASP/SANS Category:- A02:2025 Security Misconfiguration

Description:- External Control of System or Configuration Setting occurs when an application allows external users or untrusted sources to modify system configuration parameters or environment settings. If configuration values such as file paths, system variables, or application settings are controlled by user input without proper validation, attackers may manipulate them to change the behavior of the system.

Business Impact:- This vulnerability may allow attackers to alter system configurations, access restricted resources, or manipulate application functionality. In severe cases, attackers may gain unauthorized privileges, modify system behavior, or compromise sensitive data within the application environment.



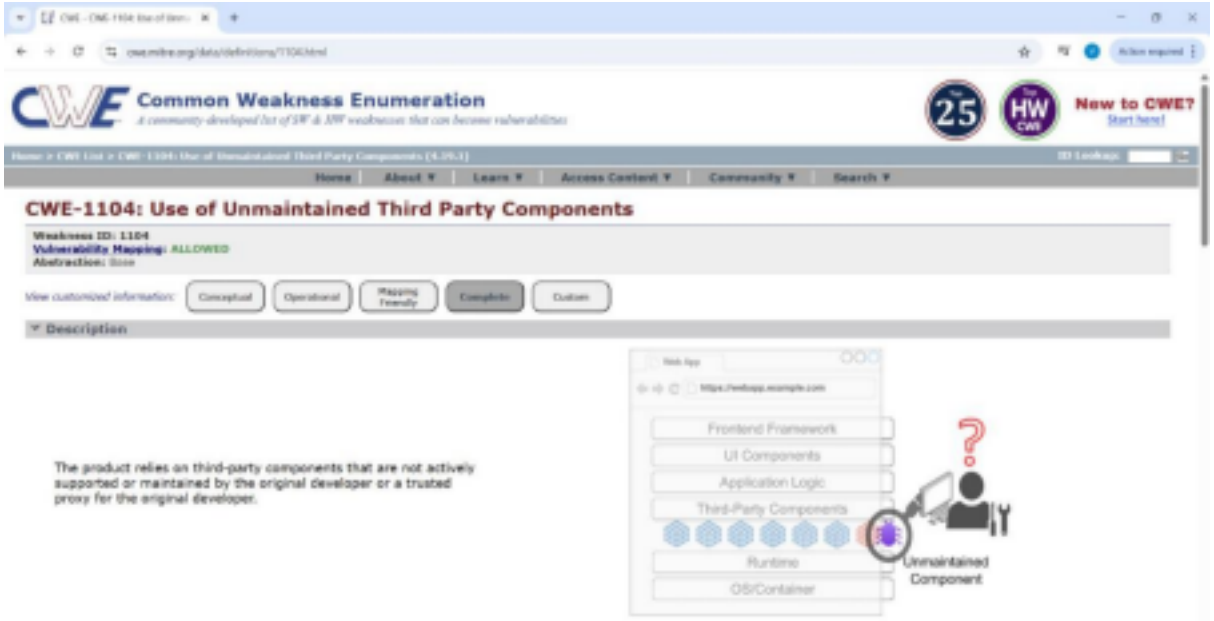
3)Vulnerability Name : Use of Unmaintained Third Party Components

CWE/CVE:- CWE-1104

OWASP/SANS Category:- A03:2025 Software Supply Chain Failures

Description:- The product relies on third-party components that are not actively supported or maintained by the original developer or a trusted proxy for the original developer.

Business Impact:- Outdated third-party components may contain known security vulnerabilities. Attackers can exploit these weaknesses to gain unauthorized access or compromise the system.



4)Vulnerability Name :- Missing Cryptographic Step

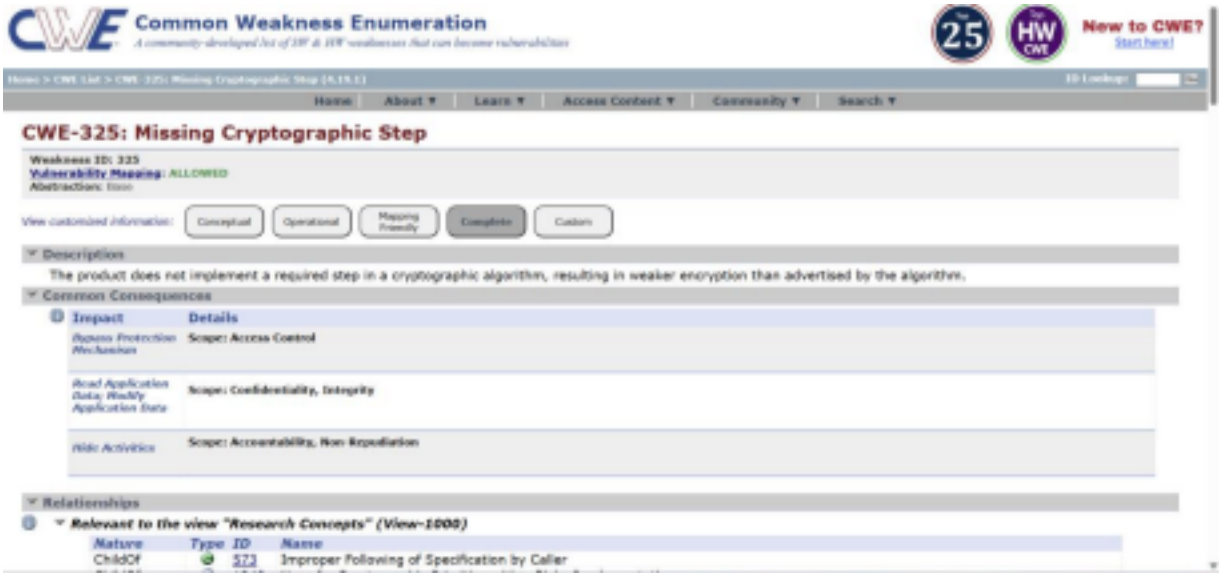
CWE/CVE:- CWE-325

OWASP/SANS Category:- A04:2025 Cryptographic Failures

Description:- Missing Cryptographic Step occurs when an application fails to apply required cryptographic protection during data processing or communication. This may include not encrypting sensitive data, failing to use secure hashing techniques, or not implementing secure key management. Without proper cryptographic mechanisms, sensitive

information may be exposed during storage or transmission.

Business Impact:- Attackers may intercept or access sensitive information such as user credentials, personal data, or financial records. This can result in data breaches, unauthorized access, loss of confidentiality, and potential legal or regulatory consequences for the organization.



5)Vulnerability Name :- Improper Neutralization of Equivalent Special Elements

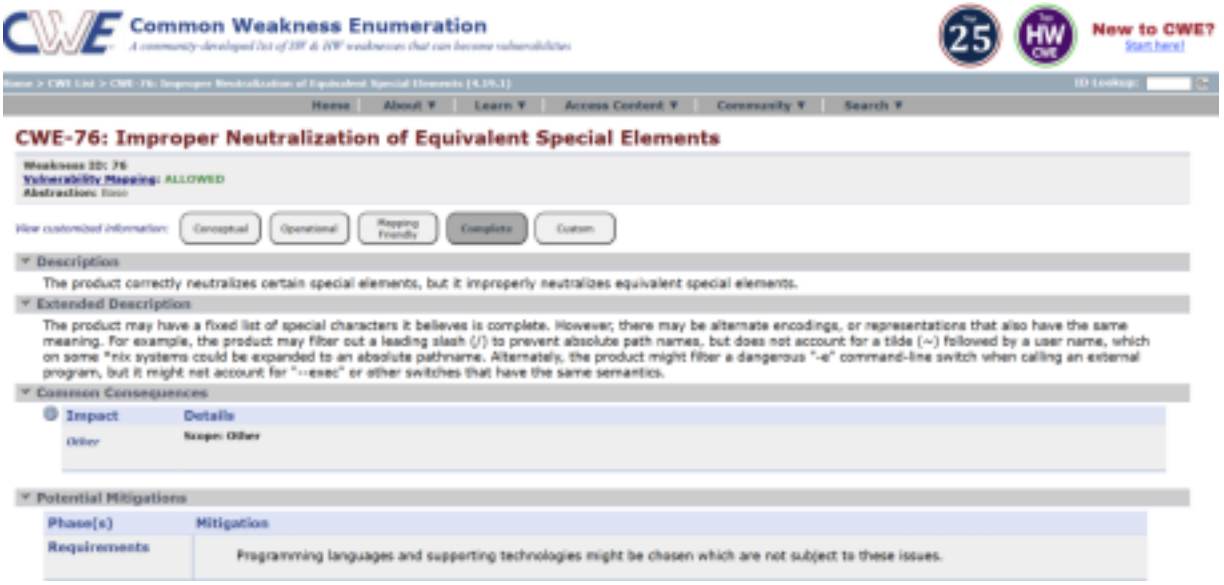
CWE/CVE:- CWE-76

OWASP/SANS Category:- A05:2025 Injection

Description:- Improper Neutralization of Equivalent Special Elements occurs when an application fails to properly sanitize or filter input containing special characters that may be interpreted differently by the system. Attackers can manipulate these characters to alter application behavior and inject malicious commands or queries.

Business Impact:- If exploited, attackers may execute unauthorized commands,

manipulate database queries, or access sensitive data. This can lead to data breaches, system compromise, and disruption of application functionality.



6)Vulnerability Name :-External Control of File Name or Path

CWE/CVE:- CWE-73

OWASP/SANS Category:- A06:2025 Insecure Design

Description:- The product allows user input to control or influence paths or file names that are used in filesystem operations.

Business Impact:- Attackers may manipulate file names or paths to access or modify unauthorized files. This can lead to data exposure or unauthorized file operations.

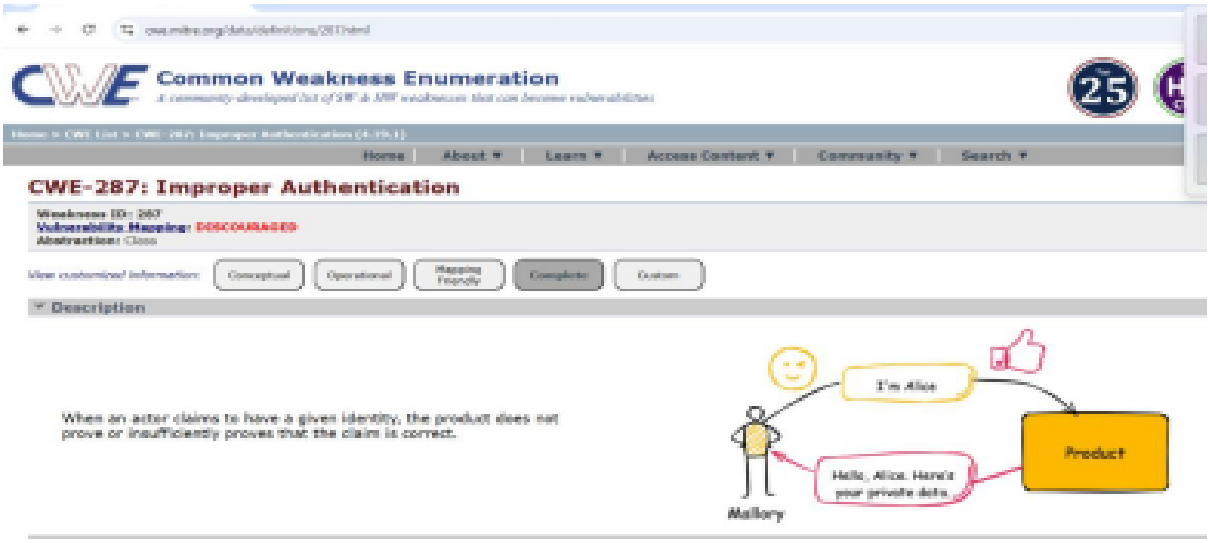
7)Vulnerability Name :- Improper Authentication File

CWE/CVE:- CWE-287

OWASP/SANS Category:- A07:2025 Authentication Failures

Description:- When an actor claims to have a given identity, the product does not prove or insufficiently proves that the claim is correct.

Business Impact:- Weak authentication mechanisms may allow unauthorized users to access protected systems or accounts. This can lead to data breaches and misuse of sensitive information.



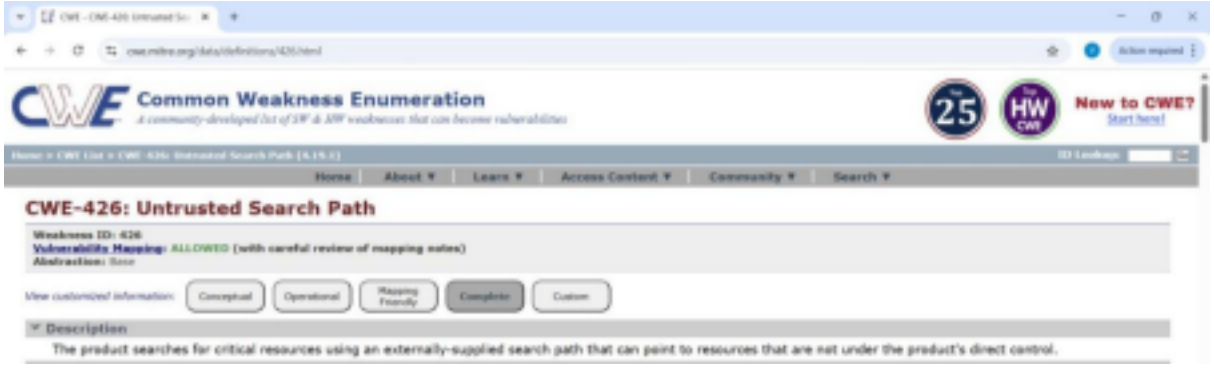
8)Vulnerability Name:- Untrusted Search Path

CWE/CVE:- CWE-426

OWASP/SANS Category:-A08:2025 Software or Data Integrity Failures

Description:- Untrusted Search Path vulnerability occurs when an application loads executables or libraries from directories that are not properly secured. If an attacker can place a malicious file in a directory that the application searches first, the system may execute the malicious file instead of the legitimate one.

Business Impact:- Attackers may exploit this vulnerability to run malicious code within the system. This could lead to unauthorized system access, modification of application behavior, or complete system compromise.



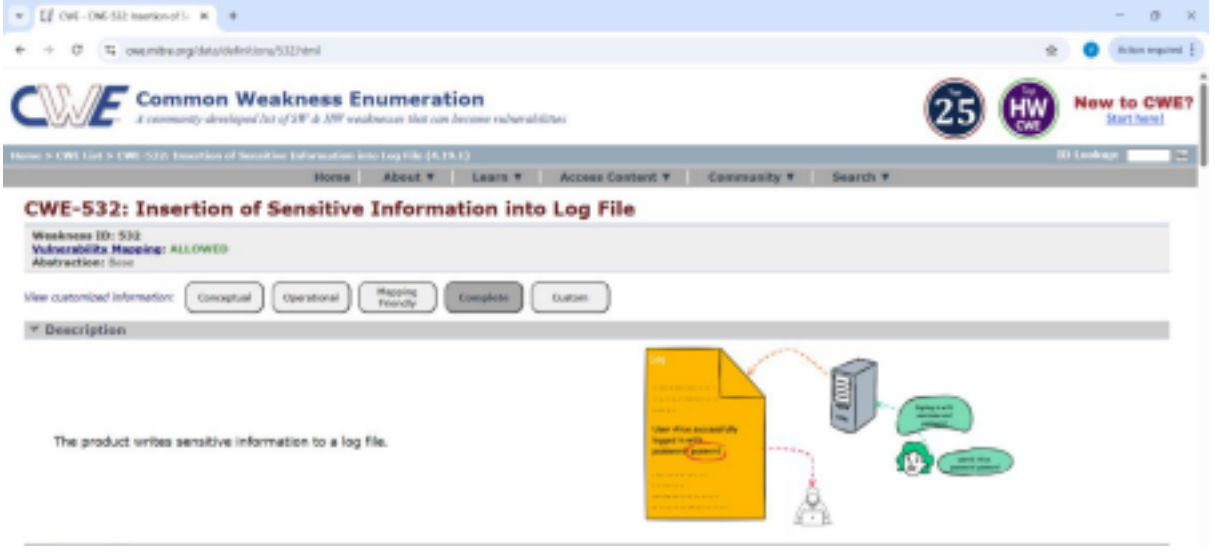
9)Vulnerability Name :- Insertion of Sensitive Information into Log File

CWE/CVE:- CWE-532

OWASP/SANS Category:-A09:2025 Security Logging & Alerting Failures

Description:- The product writes sensitive information to a log file.

Business Impact:.Sensitive information such as passwords or personal data stored in log files may be accessed by unauthorized users. This could result in data leakage and privacy issues.



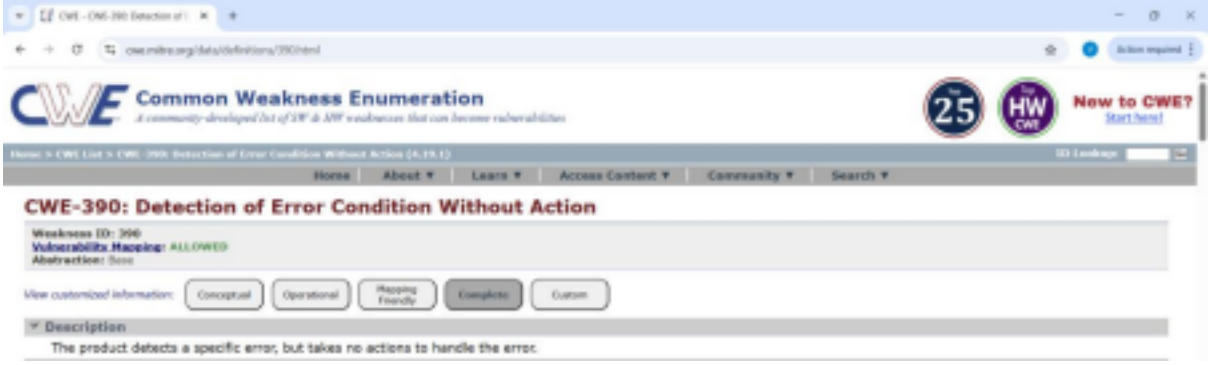
10)Vulnerability Name:Detection of Error Condition Without Action

CWE/CVE:-CWE 460

OWASP/SANS Category:- A10:2025 Mishandling of Exceptional Conditions

Description:-The product detects a specific error, but takes no actions to handle the error.

Business Impact:- If the system detects errors but does not take appropriate action, security problems may remain unresolved. Attackers may exploit these weaknesses to compromise the system.


Common Weakness Enumeration
A community-developed list of SW & HW weaknesses that can become vulnerabilities
Top 25
Top HW CWE
New to CWE?
Start here!
Home > CWE List > CWE-390: Detection of Error Condition Without Action (4.19.1)
ID Lookup:
Home
About
Learn
Access Content
Community
Search
CWE-390: Detection of Error Condition Without Action
Weakness ID: 390
Vulnerability Mapping: ALLOWED
Abstraction: Base
View customized information:
Conceptual
Operational
Mapping Friendly
Complete
Custom
Description
The product detects a specific error, but takes no actions to handle the error.

STAGE 2

TITLE: NESSUS SCAN

Overview:

Tenable Nessus is one of the most widely used vulnerability assessment tools in cybersecurity. It is developed by Tenable and is designed to help organizations identify security weaknesses in their systems, networks, and applications. Nessus scans computers, servers, network devices, and web applications to detect vulnerabilities that attackers could exploit. By identifying these weaknesses early, organizations can fix them before they become serious security problems.

Nessus works by performing automated vulnerability scans on the target systems. During the scan, it checks for known security issues such as outdated software, missing security patches, configuration errors, weak passwords, and exposed services. The tool compares the scanned system with a large database of known vulnerabilities, including entries from the Common Vulnerabilities and Exposures (CVE) list. When vulnerabilities are detected, Nessus generates a detailed report explaining the issue and suggesting ways to fix it.

One of the main advantages of Nessus is its ability to provide accurate vulnerability detection. It uses regularly updated vulnerability plugins to detect new threats and security risks. These plugins allow the tool to check thousands of vulnerabilities across different operating systems and applications. Nessus also classifies vulnerabilities based on their severity levels such as critical, high, medium, and low. This helps security teams prioritize which vulnerabilities should be fixed first.

From my understanding, Nessus is an essential tool for maintaining strong cybersecurity in organizations. It helps identify weaknesses in systems before attackers can exploit them. By regularly scanning systems and fixing

vulnerabilities, organizations can reduce the chances of cyberattacks and protect sensitive data. Therefore, vulnerability scanning tools like Nessus play an important role in maintaining the overall security of modern IT infrastructures.

1)Vulnerability Scanning Tool

Tenable Nessus is a security tool used to scan computers, servers, and networks to identify security vulnerabilities and weaknesses.

2)Detects Security Risks

It helps detect issues such as outdated software, missing security patches, weak configurations, and known vulnerabilities in systems.

3)Uses CVE Database

Nessus compares scanned systems with vulnerability databases like **Common Vulnerabilities and Exposures (CVE)** to identify known security threats.

4)Provides Detailed Reports

After scanning, it generates detailed reports showing vulnerability descriptions, severity levels, and recommended solutions.

5)Improves System Security

By identifying and fixing vulnerabilities found by Nessus, organizations can improve their network security and reduce the risk of cyberattacks.

Target website :- https://ginandjuice.shop/

Target ip address: - 34.246.169.176

List of vulnerability: -

s.no	Vulnerability name	Severity	plugins
1	**SSL Certificate Information**	Info	10863
2	**Service Detection**	Info	22964
3	**Nessus SYN scanner**	Info	11219
4	**HSTS Missing From HTTPS Server (RFC 6797)**	Medium	142960
5	**Shor's Harvest Now Decrypt Later**	Info	298387

REPORT: -

1)Vulnerability Name:- SSL Certificate Information severity:
- Info

Plugin: -10863

Description:- This plugin connects to every SSL-related port and attempts to extract and dump the X.509 certificate.

solution:-n/a

Business Impact::- Exposure of SSL certificate details may reveal information about the server and organization. Attackers can use this information to plan targeted attacks against the system.

2)Vulnerability Name:- Service Detection severity:
-Info

Plugin: -22964

Description:- Nessus was able to identify the remote service by its banner or by looking at the error message it sends when it receives an HTTP request.

solution:-n/a

Business Impact::- When services running on a system are easily detectable, attackers can identify open ports and services. This information may help them find vulnerabilities and attempt unauthorized access.

3)Vulnerability Name:- Nessus SYN scanner severity:
-Info

Plugin: -11219

Description:-

This plugin is a SYN 'half-open' port scanner. It shall be reasonably quick even against a firewalled target. Note that SYN scans are less intrusive than TCP (full connect) scans against broken services, but they might cause problems for less robust firewalls and also leave unclosed connections on the remote target, if the network is loaded. **solution:-** Protect your target with an IP filter.

Business Impact::- The detection of SYN scanning indicates that systems may be probed to identify open ports and active hosts. Attackers can use this information to map the network and prepare further attacks.

4)Vulnerability Name:- HSTS Missing From HTTPS Server (RFC 6797)

severity: - Medium

Plugin: -142960

Description:- The remote web server is not enforcing HSTS, as defined by RFC 6797. HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL-stripping man-in-the-middle attacks, and weakens cookie-hijacking protections. **solution:-** Configure the remote web server to use HSTS.

Business Impact::- Without HTTP Strict Transport Security, users may be vulnerable to man-in-the-middle attacks. Attackers could intercept or manipulate sensitive data transmitted between the user and the server.

5)Vulnerability Name:- Shor's Harvest Now Decrypt Later severity:

Plugin: 298387

Description:- This plugin reports network services that may be vulnerable now to a future attack by adversaries using a cryptographically relevant quantum computer(CRQC).

Shor's is a theoretical algorithm that leverages the unique ability of quantum computation to do massively parallel calculations developed by Peter Shor in 1994.

This algorithm easily computes two classically difficult mathematical problems used in modern cryptography; discrete logarithms, and factoring numbers formed by multiplying large primes. Shor's reduces both of these problems from taking exponential time in chosen cases to being solvable in polynomial time.

Asymmetric encryption algorithms such as RSA, Diffie-Hellman and Elliptic Curve Diffie Hellman are impacted by Shor's Algorithm. The most common uses of these algorithms are in symmetric key establishment and authentication. These uses render Shor's Algorithm particularly dangerous because it may give an adversary the ability to harvest network communications now, and in the future, when a CRQC becomes available, extract the symmetric key and decrypt the communication.

solution:- Replace affected ciphers with algorithms chosen to resist CRQC attack.

Business Impact::- Attackers may collect encrypted data today with the intention of decrypting it in the future using quantum computing techniques.
This could expose sensitive data and confidential communications later.

STAGE 3

Report:

Title: - Implement and manage Zero Trust Network Access (ZTNA) using Zscaler by enabling secure, identity-based user to application connectivity without exposing internal networks.

A Security Operations Center (SOC) is a centralized team or facility responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats in an organization. The SOC team continuously observes network traffic, system activities, and security alerts to identify suspicious behavior or potential attacks. Security analysts in the SOC use various security tools and technologies to investigate incidents and prevent damage to systems and data. The main goal of a SOC is to ensure the confidentiality, integrity, and availability of an organization's information systems. It plays a crucial role in protecting businesses from cyber threats and maintaining strong cybersecurity.

The SOC cycle refers to the continuous process followed by a Security Operations Center to manage security incidents effectively. It usually includes stages such as monitoring, detection, analysis, response, and recovery. First, the SOC continuously monitors systems and networks for unusual activities. When a potential threat is detected, analysts investigate and analyze the incident to determine its severity and impact. After analysis, the SOC team responds to the threat by taking appropriate actions such as blocking attackers or removing malicious software. Finally, the recovery stage ensures that systems are restored and improved to prevent similar attacks in the future.

Security Information and Event Management (SIEM) is a cybersecurity technology used to collect, analyze, and manage security data from multiple sources within an organization. It gathers logs and security events from servers,applications, network devices, and security tools.SIEM systems analyze this information in real time to detect

suspicious activities and potential cyber threats.They also provide alerts and detailed reports to help security teams investigate incidents quickly. By using SIEM tools, organizations can improve their ability to detect attacks, respond to security incidents, and maintain better visibility of their IT infrastructure.

The SIEM cycle describes the process followed by Security Information andEvent Management systems to manage security information effectively. The cycle begins with data collection, where logs and events are gathered from various devices and systems. Next is data normalization and correlation, where the collected data is analyzed and related events are connected to identify suspicious patterns. After this, the SIEM system generates alerts for possible security incidents. Security analysts then investigate these alerts and take necessary actions to respond to threats. Finally, the system stores the data for future analysis, reporting, and compliance purposes.

Malware Information Sharing Platform (MISP) is an open-source threat intelligence platform used for sharing cybersecurity information among organizations. It helps security teams collect, store, and share information about cyber threats such as malware, attack techniques, and indicators of compromise (IOCs). By sharing threat intelligence, organizations can learn from each other and respond more quickly to cyberattacks. MISP also helps security teams analyze threats and identify patterns that may indicate potential attacks. Overall,it improves collaboration and strengthens the ability of organizations to defend against cyber threats.

CONCLUSION:

Stage 1: Web application testing is the process of checking web applications for security vulnerabilities and functional issues. It helps identify weaknesses that attackers could exploit to access sensitive data or disrupt services. During testing, security professionals examine areas such as input validation, authentication, session management, and configuration settings. The main goal is to ensure that the web application is secure and reliable for users. This testing also helps prevent attacks like SQL injection and cross-site scripting. By detecting vulnerabilities early, developers can fix issues before deployment. It also improves the overall quality and

performance of the application. Therefore, web application testing plays a major role in protecting web-based systems and user information.

Stage 2: The Tenable Nessus report provides detailed information about vulnerabilities present in systems and networks. It shows different security weaknesses detected during the vulnerability scanning process. The report categorizes vulnerabilities based on their severity levels such as critical, high, medium, and low. It also includes descriptions of the vulnerabilities and recommendations to fix them. By analyzing the report, security teams can understand which vulnerabilities need immediate attention. This helps organizations prioritize security patches and configuration updates. The report also improves awareness about potential cyber risks. Overall, Nessus reports help organizations strengthen their cybersecurity posture.

Stage 3: SOC and SIEM dashboards help security teams monitor network activities and detect security threats in real time. Tools like IBM QRadar collect logs and security events from various devices and systems. These tools analyze the collected data to identify suspicious activities or possible cyberattacks. The dashboard displays alerts, threat levels, and security event details for analysis. Security analysts use this information to investigate incidents and take quick action. It also helps organizations maintain continuous monitoring of their IT infrastructure. SOC and SIEM systems improve visibility into network security events. Overall, these dashboards help organizations detect, analyze, and respond to cyber threats effectively.

Future Scope: -

Stage 1 :- Web application testing will continue to evolve with the growth of cloud computing and modern web technologies. Advanced automated security testing tools and AI-based vulnerability detection will improve the speed and accuracy of testing. This will help organizations develop more secure and reliable web applications

.Stage 2 :- In the future, the testing process will become more automated and integrated with development processes like DevSecOps. Continuous security

testing will help detect vulnerabilities early in the development lifecycle. This will reduce security risks and improve the overall quality of software systems.

Stage 3 :- SOC and Security Information and Event Management (SIEM) systems will become more intelligent with the use of artificial intelligence and machine learning. These technologies will help detect threats faster and reduce false alerts.Future SOC environments will provide stronger real-time monitoring and faster incident response.

Topics Explored

- Web Application Security Testing
- Vulnerability Assessment and Management
- Common Web Application Vulnerabilities (OWASP Top Vulnerabilities) • Security Operations Center (SOC) Concepts
- Security Information and Event Management (SIEM)
- Threat Monitoring and Incident Detection
- Log Analysis and Security Event Monitoring
- Cybersecurity Risk Identification and Mitigation

Tools Explored

- Tenable Nessus – Vulnerability scanning tool used to detect security weaknesses.
- IBM QRadar – SIEM platform used for security monitoring and threat detection.
- Malware Information Sharing Platform – Threat intelligence sharing platform used for cybersecurity collaboration.